

Módulo 3 - Seguridad de Redes

Seguridad en redes

1. Fundamentos de la Comunicación: ¿Qué son los Puertos?

En el marco de la arquitectura de protocolos TCP/IP, específicamente en la **capa de transporte**, un **puerto** es un identificador numérico utilizado para dirigir los datos a una aplicación o servicio específico dentro de un sistema informático. Mientras que la dirección IP identifica de forma única a un host en la red, los puertos permiten que múltiples aplicaciones se ejecuten simultáneamente en el mismo equipo sin que sus flujos de datos se mezclen.

- **Definición técnica:** Cada proceso o aplicación que desea comunicarse a través de la red debe tener una dirección que sea única dentro del computador; estas direcciones se denominan técnicamente **puertos**.
 - **Puntos de Entrada y Riesgo:** Un "puerto abierto" indica que hay un servicio escuchando y listo para responder a solicitudes externas. Desde la perspectiva de la ciberseguridad, cada puerto abierto representa un punto de entrada potencial y, por lo tanto, incrementa la **superficie de ataque** del sistema.
-

2. Visibilidad y Auditoría: Escaneo de Servicios

El proceso de **escaneo de puertos** es la técnica fundamental para descubrir dispositivos e identificar qué servicios están expuestos en una red. Herramientas como **Nmap** permiten a los profesionales de seguridad priorizar los objetivos de **hardening** (reforzamiento) al clasificar los puertos en tres estados principales:

- **Abierto:** El servicio acepta conexiones (ej. un servidor web en el puerto 80).
- **Cerrado:** No hay ninguna aplicación escuchando en ese puerto.
- **Filtrado:** Un firewall o control de red está bloqueando el acceso, impidiendo determinar si el puerto está realmente abierto o cerrado.

3. Tabla Técnica de Puertos y Servicios Comunes

A continuación, se presenta una referencia exhaustiva de los puertos estándar, sus protocolos asociados y su función técnica, diferenciando entre versiones seguras e inseguras según los estándares de la industria.

Puerto	Protocolo	Servicio / Función	Nivel de Seguridad
21	TCP	FTP (File Transfer Protocol): Transferencia de archivos.	Inseguro: Envía datos y claves en texto plano.
22	TCP	SSH (Secure Shell): Acceso remoto seguro y túneles cifrados.	Seguro: Reemplazo estándar para Telnet y FTP.
23	TCP	Telnet: Acceso remoto de línea de comandos.	Inseguro: Vulnerable a ataques de espionaje (<i>eavesdropping</i>).
25	TCP	SMTP: Protocolo para el envío de correo electrónico.	Estándar (requiere TLS para ser seguro).
53	UDP/TCP	DNS (Domain Name System): Resolución de nombres a IPs.	Crítico (se protege mediante DNSSEC).
80	TCP	HTTP: Tráfico web estándar sin cifrar.	Inseguro: El contenido es visible mediante captura de paquetes.
110	TCP	POP3: Recuperación de correos electrónicos.	Inseguro (se debe usar POP3S sobre TLS).
143	TCP	IMAP: Acceso y gestión de correos en el servidor.	Inseguro (se debe usar IMAPS).

161/162	UDP	SNMP: Gestión y monitoreo de dispositivos de red.	La versión 3 (SNMPv3) añade cifrado necesario.
389	TCP/UDP	LDAP: Acceso a servicios de directorio (identidad).	Inseguro (se debe migrar a LDAPS en puerto 636).
443	TCP	HTTPS: Tráfico web seguro envuelto en TLS.	Seguro: Garantiza confidencialidad e integridad.
445	TCP	SMB: Intercambio de archivos en redes Microsoft.	Común (objetivo frecuente de malware/gusanos).
636	TCP	LDAPS: LDAP sobre SSL/TLS.	Seguro: Versión cifrada para proteger directorios.
3389	TCP/UDP	RDP (Remote Desktop Protocol): Escritorio remoto Windows.	Crítico (debe protegerse con MFA y Firewalls).

4. Arquitecturas de Defensa Perimetral (Firewalls)

Para profundizar en el eje de **Seguridad de Redes**, es fundamental establecer una definición técnica sólida de lo que representa esta barrera defensiva.

Un **firewall** (o cortafuegos) es un **dispositivo o software de control de seguridad** diseñado para proteger los activos de información al **limitar y filtrar los tipos de tráfico de red** que pueden entrar o salir del perímetro seguro de una organización. Actúa como una barrera entre una red de confianza (interna) y una red que no es de confianza (como Internet).

Sus características y funciones principales, según las fuentes técnicas, son:

- **Mecanismo de Control:** Opera mediante la implementación de **Listas de Control de Acceso (ACL)**, que son un conjunto de reglas granulares que dictan si un paquete de datos puede pasar o no, basándose en criterios como la **dirección IP** de origen/destino, el **puerto** y el **protocolo** utilizado.

- **Objetivo de Seguridad:** Su función primordial es prevenir el acceso no autorizado a la información, protegiendo así la **confidencialidad, integridad y disponibilidad** de los sistemas.

- **Clasificación por Ubicación:**
 - **Firewall basado en host:** Es un software instalado directamente en un sistema operativo (como el que viene integrado en Windows o Linux) que protege a ese dispositivo específico.

 - **Firewall de red:** Es un dispositivo dedicado (hardware o instancia virtual) que protege a todo un segmento o grupo de sistemas dentro de una arquitectura de red.

- **Modos de Operación:**
 - **Sin estado (Stateless):** Filtra cada paquete de forma individual basándose solo en los encabezados, sin considerar el contexto de la comunicación.

 - **Con estado (Stateful):** Rastrea flujos de tráfico completos y mantiene una "tabla de estado", lo que le permite entender el contexto de una conversación técnica y tomar decisiones más inteligentes.

- **Evolución Tecnológica:** Actualmente existen los **Firewalls de Próxima Generación (NGFW)**, que integran funciones avanzadas como inspección profunda de paquetes, sistemas de prevención de intrusiones (IPS), antimalware y filtrado de aplicaciones en un solo dispositivo.

En resumen, el firewall es el componente central de la **defensa perimetral**, encargado de vigilar las "puertas" lógicas de los sistemas para asegurar que solo el tráfico legítimo y autorizado pueda transitar por la red

5. Monitoreo y Cifrado en Tránsito

Cuando los datos viajan por la red ("datos en el cable"), son susceptibles de ser interceptados.

5. 1. Sistemas de Detección y Prevención de Intrusos (IDS e IPS)

Un **IDS** (*Intrusion Detection System*) y un **IPS** (*Intrusion Prevention System*) son herramientas críticas diseñadas para identificar y gestionar amenazas que transitan

por la red. La diferencia fundamental radica en su capacidad de respuesta: mientras que el **IDS es un sistema pasivo** que monitorea el tráfico y genera alertas cuando detecta una actividad sospechosa, el **IPS es un sistema activo**.

Un IPS se ubica "en línea" (*inline*) con el flujo de datos, lo que le permite no solo detectar una amenaza, sino también intervenir técnicamente para bloquearla o descartar los paquetes maliciosos antes de que alcancen su objetivo.

Estos sistemas pueden implementarse a nivel de red (**NIDS/NIPS**), mediante dispositivos dedicados o instancias virtuales que vigilan segmentos enteros, o a nivel de host (**HIDS/HIPS**), instalándose directamente en servidores o estaciones de trabajo para proteger el sistema operativo y las aplicaciones locales. En una arquitectura de **defensa en profundidad**, es común ver ambos tipos trabajando juntos; por ejemplo, un IPS de red filtrando ataques externos generales y un HIPS analizando el tráfico específico que llega a un servidor crítico después de haber pasado por los filtros perimetrales.

Para identificar ataques, estos sistemas utilizan tres métodos principales de detección:

- **Basada en firmas:** Busca huellas digitales o patrones de archivos conocidos asociados a malware o exploits específicos.
- **Heurística o basada en comportamiento:** Analiza patrones de acciones para detectar anomalías que coincidan con comportamientos típicos de una amenaza, incluso si la firma no es conocida.
- **Basada en anomalías:** Establece primero una "línea de base" del comportamiento normal de la red y activa una alarma cuando el tráfico se desvía significativamente de ese estándar

5. 2. El Protocolo SSL/TLS: Cifrado en Movimiento

El protocolo **TLS** (*Transport Layer Security*), y su predecesor ahora obsoleto **SSL** (*Secure Sockets Layer*), son los estándares fundamentales para proteger los "**datos en el cable**" o en tránsito a través de redes que no son de confianza, como Internet. Su función principal es "envolver" otros protocolos de texto plano para garantizar la **confidencialidad** (que nadie espíe los datos) y la **integridad** (que los datos no sean alterados). Por ejemplo, cuando se aplica sobre HTTP, el resultado es el protocolo seguro **HTTPS**; de igual forma ocurre con **LDAPS**, **IMAPS** o **POPS**.

El funcionamiento de TLS se basa en una combinación de técnicas criptográficas conocida como **criptografía híbrida**. Al inicio de una sesión, utiliza **criptografía asimétrica** (claves públicas y privadas) para autenticar al servidor mediante un **certificado digital X.509** y acordar de forma segura una clave de sesión. Una vez

establecido el enlace, el sistema cambia a **criptografía simétrica** (clave compartida) para el resto de la comunicación, ya que esta es miles de veces más rápida y eficiente para procesar grandes volúmenes de datos.

Para que este proceso sea confiable, TLS depende de una **Infraestructura de Clave Pública (PKI)** y de las **Autoridades de Certificación (CA)**. Las CA son entidades de confianza que firman los certificados digitales para validar que una clave pública realmente pertenece al servidor que dice ser. Si un analista utiliza herramientas como **Wireshark**, podrá observar que sin el uso de estos certificados y el cifrado TLS, cualquier dato enviado (como contraseñas en un formulario) viajaría en texto claro y podría ser interceptado y leído fácilmente por un atacante

5.3. PFS: Perfect Forward Secrecy (Secreto Directo Perfecto)

El concepto de **Perfect Forward Secrecy (PFS)** es una propiedad avanzada de los protocolos de comunicación segura, como TLS y WPA3, que garantiza la resiliencia de las comunicaciones pasadas. En sistemas tradicionales que no utilizan PFS, si la clave privada a largo plazo de un servidor se viera comprometida en el futuro, un atacante que hubiera interceptado y almacenado tráfico cifrado meses atrás podría utilizar esa clave para descifrar todas las conversaciones históricas. PFS elimina este riesgo al asegurar que el compromiso de una clave actual no exponga los datos de sesiones anteriores.

Para lograr esto, PFS se fundamenta en el uso de **claves efímeras**, las cuales se generan de forma única para cada sesión y se descartan inmediatamente después de su uso. El mecanismo técnico más común es el intercambio de claves de **Diffie-Hellman efímero**, un proceso matemático que permite a dos partes acordar una clave compartida a través de un canal inseguro sin necesidad de enviarla nunca. Al generar una clave temporal distinta para cada conexión, se crea un sistema donde cada sesión es un compartimento estanco de seguridad.

En términos de ciberdefensa, la implementación de PFS mediante herramientas como **OpenSSL** es una recomendación crítica para proteger activos de información altamente sensibles. Esta tecnología proporciona una capa de defensa en profundidad que mitiga el impacto de una brecha de seguridad masiva, limitando el daño exclusivamente a la sesión activa en el momento del compromiso. Es la base de la navegación anónima avanzada y es obligatoria en los estándares modernos para garantizar que la confidencialidad se mantenga íntegra a lo largo del tiempo

6. Seguridad Inalámbrica y Capa 2

6.1. WPA3 (Wi-Fi Protected Access 3)

El estándar **WPA3** representa la evolución crítica en la seguridad de redes radioeléctricas, reemplazando a WPA2 para abordar vulnerabilidades estructurales

en la autenticación y el cifrado. Mientras que WPA2 dependía de una clave pre-compartida (PSK) vulnerable a ataques de fuerza bruta fuera de línea, WPA3 introduce el protocolo **SAE (Simultaneous Authentication of Equals)** o "Autenticación Simultánea de Iguales".

Este mecanismo requiere una interacción técnica activa entre el cliente y el punto de acceso para validar ambos extremos de la conexión, lo que ralentiza drásticamente los intentos de adivinación de contraseñas y protege incluso contra claves débiles.

Una de las ventajas técnicas más significativas de WPA3 es la implementación obligatoria de **Perfect Forward Secrecy (PFS)** o "Secreto Directo Perfecto". A diferencia de los modelos anteriores, PFS utiliza un proceso criptográfico que genera claves de sesión únicas y temporales para cada comunicación; esto garantiza que, si una contraseña o clave se ve comprometida en el futuro, los datos capturados y almacenados de sesiones pasadas sigan siendo indescifrables.

Además, WPA3 eleva los estándares en entornos corporativos con el modo **WPA3-Enterprise**, que ofrece un cifrado opcional de 192 bits y mayor protección para las tramas de administración de la red.

Para redes públicas o abiertas, WPA3 incorpora la certificación **Wi-Fi Enhanced Open**, basada en el protocolo **OWE (Opportunistic Wireless Encryption)**. Esta tecnología permite que el tráfico inalámbrico sea cifrado de forma individual para cada usuario sin necesidad de una contraseña común, eliminando el riesgo de que un vecino de red espíe las comunicaciones ajenas en texto plano. Finalmente, WPA3 exige la protección de marcos de gestión, lo que neutraliza ataques clásicos de **Disociación** (forzar la desconexión de un usuario), proporcionando un entorno mucho más resiliente frente a los intentos de manipulación de la infraestructura inalámbrica.

6.2. Amenazas de Capa 2 (Enlace de Datos)

La **Capa 2** del modelo OSI es el puente crítico entre el hardware físico y el direccionamiento lógico; por ello, los ataques en este nivel son letales ya que suelen ocurrir dentro de los límites del perímetro de seguridad. El **ARP Spoofing** (o envenenamiento de la caché ARP) es una de las amenazas más comunes; consiste en enviar paquetes ARP maliciosos a la puerta de enlace para asociar la dirección MAC del atacante con la dirección IP de una víctima legítima. Esto permite realizar ataques **On-path** (anteriormente llamados *Man-in-the-Middle*), donde el atacante intercepta, lee o altera el tráfico antes de retransmitirlo a su destino real.

Otra vulnerabilidad estructural es el **MAC Flooding** (Inundación de MAC), que aprovecha las limitaciones físicas de la **Tabla CAM (Content Addressable Memory)** de los switches. Esta tabla almacena los emparejamientos de puertos y direcciones MAC para dirigir el tráfico de forma eficiente; si un atacante inunda el switch con

miles de direcciones MAC falsas hasta llenar la tabla, el dispositivo entra en un estado de "falla abierta" y comienza a transmitir todo el tráfico a todos los puertos, permitiendo que el atacante capture datos que de otro modo serían privados. Para mitigar esto, se debe implementar **Port Security** (Seguridad de Puerto), limitando el número de MACs permitidas por puerto físico.

Finalmente, las redes deben protegerse contra los **Broadcast Storms** (Tormentas de Difusión) y los bucles de red. Un bucle ocurre cuando el tráfico se retransmite infinitamente entre conmutadores mal configurados, causando una amplificación masiva que agota el ancho de banda y anula la disponibilidad de la red. La defensa estándar es el protocolo **STP (Spanning Tree Protocol)**, que detecta estos bucles y deshabilita puertos de forma lógica para mantener la integridad de la topología. Complementariamente, técnicas como el **DHCP Snooping** previenen que atacantes instalen servidores DHCP falsos para asignar IPs y puertas de enlace maliciosas a los usuarios de la red